Note de synthèse

Besoin de capital et conformité à DORA

Modélisation et identification partielle

Kélian Kaddouri

ENSAE Paris, filière Actuariat

Nexialog Consulting

2026

Ce document reprend, à l'identique et sans ajout, les deux notes de synthèse qui ouvrent le mémoire. Il est fourni séparément pour l'indexation et le référencement prévus au § 6.5 des Recommandations Jury. Chaque nombre qui y figure est une valeur publiée dans le corps du mémoire, où il porte la citation du script qui la produit ; la note n'en calcule aucun.

Note de synthèse

Contexte et objectif

Comment le besoin de capital varie-t-il entre états de conformité supposés ? Nous calculons cet écart, puis examinons ce qui en subsiste quand la direction de la contagion et les coûts par pilier ne sont pas observés. Les montants restent conditionnels à ces hypothèses. Le règlement européen DORA distingue cinq domaines, appelés ici piliers : gouvernance (P1), incidents (P2), tests (P3), prestataires tiers (P4) et partage d'informations (P5). La charge de risque opérationnel de la Formule Standard ne dépend pas directement de leur conformité.

Le risque mesuré est le risque opérationnel d'origine informatique de l'entité. Les pénalités réglementaires et le risque de souscription des polices cyber qu'un assureur vend ne sont pas modélisés. Nous répartissons l'écart entre les cinq piliers et entre quatre paramètres du modèle que la non-conformité modifie, que nous appelons canaux : la fréquence des incidents, leur détection, leur propagation d'un pilier à l'autre et la dépendance à un prestataire commun. Le résultat est un besoin de capital au sens de l'ORSA (évaluation interne des risques), non un SCR réglementaire.

Les montants sont en millions d'euros et valent pour le périmètre financier étudié (21,6 incidents par an), non pour un assureur ; l'ordre de grandeur d'une entité de 20 000 M$ d'actifs figure avec les résultats. Le niveau change d'un facteur 22 selon la seule source de sévérité. Sous la construction additive et les sensibilités étudiées, nous interprétons l'écart entre états et l'ordre des piliers ; le niveau reste illustratif.

Démarche

La base SAS OpRisk Global fournit 570 pertes informatiques d'institutions financières de 2000 à 2026. Une loi de Pareto généralisée, ajustée au-delà de 20,03 M€ sur 86 excès, décrit les pertes élevées (indice de queue 0,5954). Le nombre annuel d'incidents suit une loi binomiale négative. Un incident naît sur un pilier, puis se transmet aux autres selon une matrice d'influence dirigée, posée à dire d'expert puis bornée. Le capital est le quantile à 99,5 % de la charge annuelle, calculé dans chaque état.

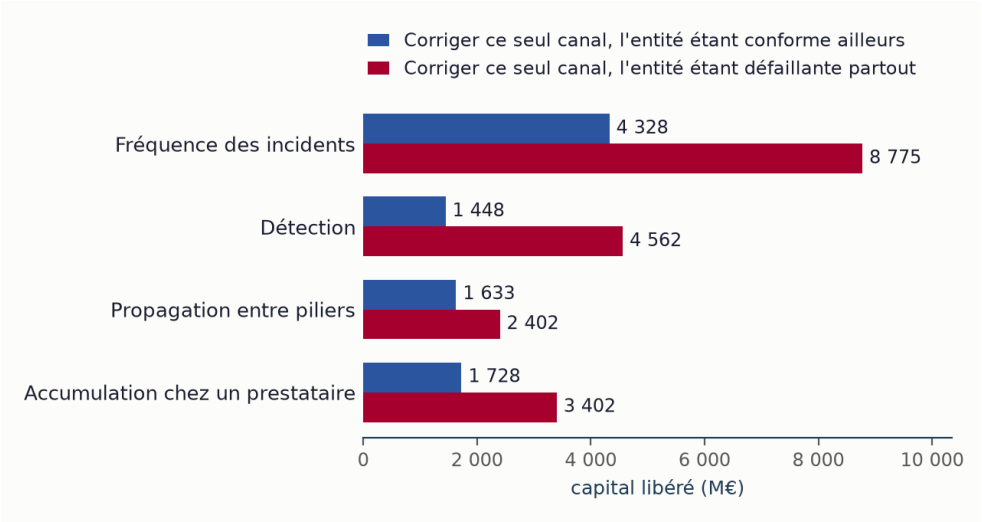
La conformité modifie les paramètres du calcul. Les parts de vecteurs d'attaque Hackmageddon pondèrent le multiplicateur de fréquence. La détection règle la probabilité qu'une perte élémentaire dépasse le seuil ; elle s'applique à chaque pilier touché. La propagation règle la poursuite de la marche entre piliers. Enfin, une amorce chez le prestataire P4 peut toucher plusieurs autres piliers par un choc commun. Le tableau donne les valeurs retenues.

Ces différences entre états sont des hypothèses de scénario. Les tests de sensibilité du chapitre 6 examinent leurs effets ; les multiplicateurs de détection ne sont pas balayés. Le calcul distingue l'effet d'un canal isolé et celui de sa correction quand les autres restent dégradés.

Canal	Paramètre	Conforme	Non conforme	Effet isolé	Effet de fermeture
Fréquence	incidents par an	21,6	53,6	4 328	8 775
Détection	dépassement par pilier	0,128	0,181	1 448	4 562
Propagation	gain de la cascade	0,45	0,90	1 633	2 402
Accumulation	prestataire commun	0	0,68	1 728	3 402
Besoin de capital (M€)		6 049	20 188		

Résultats

À l'échelle du périmètre financier étudié, le besoin de capital est multiplié par 3,34 entre l'entité conforme et l'entité non conforme sur les quatre canaux, soit un écart de 14 139 M€. Les canaux pris un à un en expliquent 9 138 M€, et leurs interactions 5 001 M€, soit 35 %. L'effet isolé est le capital ajouté par un canal seul, depuis l'état conforme. L'effet de fermeture est le capital retiré en corrigeant ce canal seul, depuis l'état non conforme sur les trois autres : un plan de remédiation doit citer ce second effet.



Capital libéré en corrigeant un seul canal (M€, périmètre financier étudié) : en bleu depuis une entité conforme ailleurs (effet isolé), en rouge depuis une entité défaillante partout (effet de fermeture). Les effets de fermeture ne s'additionnent pas.

La figure montre l'ordre des canaux. La fréquence domine dans les deux lectures. Corriger un canal rapporte toujours davantage à une entité défaillante partout, car le canal ferme aussi les interactions qu'il partageait avec les autres. Pour une entité, la priorité de remédiation dépend donc de son état de départ, et non du seul effet isolé de chaque canal.

Cet écart dépend du coût de l'incident. À calage fixé, le calcul par Fourier donne 13 946 M€ sous la règle additive, à moins d'une erreur type (367 M€) de l'estimation de Monte-Carlo, contre 5 946 avec une perte unique. Sous la règle additive, le bootstrap conjoint de la sévérité donne une bande nominale à 95 % de [4 872 ; 90 361] M€ pour l'écart, mais de [3,04 ; 5,22] pour le facteur entre états (chapitre 10). La queue rend le niveau très incertain et le facteur beaucoup moins ; ces bandes restent conditionnelles à la fréquence et aux autres paramètres posés.

Les données publiques ne disent pas quel pilier entraîne l'autre : nous calculons le capital aux 1 024 sommets de l'ensemble des matrices d'influence admissibles, la structure symétrique étant

posée à dire d'expert. Dans le calage de référence (fréquence conforme, gain 0,90), les valeurs aux sommets vont de 6 858 à 8 697 M€ ; recalculée sur quatre graines, la largeur de cette plage a un écart-type de 189 M€. La matrice se décompose en une partie symétrique, la force commune des liens, posée ici, et une partie antisymétrique, leur sens, qu'aucune des sources examinées ne fixe. Cette plage n'est ni un intervalle de confiance ni une borne démontrée : elle mesure ce que coûte l'ignorance du sens, à force posée. Pour une entité notionnelle de 20 000 M$ d'actifs, le capital du secteur est ramené à sa taille : le besoin est de l'ordre de 169 M€ (de 131,5 à 183,3 M€ aux sommets admissibles), une extrapolation d'ordre de grandeur qui dépend de la structure d'expert et de la calibration.

Limites et recommandations

La fréquence de référence inclut douze pertes d'avant 2000, soit 2,1 % de plus que l'échantillon étudié. Le chapitre 10 examine ce décalage. La propagation et l'accumulation sont posées. Les correspondances testées conservent le signe de l'écart sous la règle additive ; la perte par pilier reste non observée. Les bandes de calibration laissent fixes la fréquence, les multiplicateurs et la cascade d'expert.

Le test du rapport de vraisemblance rejette la loi de Poisson (statistique de 130,5) au profit de la binomiale négative. Un backtest sur 2004–2025 place ensuite 11 années sur 12 dans l'intervalle à 90 % de la loi binomiale négative, contre 9 sur 12 pour Poisson, ce qui conforte le choix sans le démontrer sur douze années. Le backtest rejette le niveau de la charge annuelle ; une dérive de l'échelle de queue est explorée, sans confirmation statistique. Détecter un doublement du taux de dépassement avec 80 % de puissance demanderait 1 811 années à 99,5 %.

Le modèle sert d'abord à comparer des scénarios et leurs effets de fermeture. Arrêter un capital ou un investissement réel exige de mesurer les états, les coûts et l'exposition de l'entité. Un registre daté, classé par domaine de contrôle et consignant tous les piliers touchés renseignerait la direction. VERIS prévoit ces champs ; ils sont renseignés ensemble dans un incident sur 10 591.

Executive summary

Context and objective

How does capital need vary between assumed compliance states? We calculate this gap, then examine what survives when contagion direction and pillar-level costs are unobserved. The amounts remain conditional on these assumptions. The European DORA regulation distinguishes five areas, called pillars here: governance (P1), incidents (P2), testing (P3), third-party providers (P4) and information sharing (P5). The Standard Formula operational risk charge does not directly depend on their compliance.

The risk measured is the entity's own IT-related operational risk, that is its own incidents. Regulatory penalties and the underwriting risk of the cyber policies an insurer sells are not modelled. We split the gap across the five pillars and across four model parameters that non-compliance changes, which we call channels: incident frequency, detection, propagation from one pillar to another, and dependence on a shared provider. The result is a capital need in the ORSA sense, the internal assessment of risks and solvency. It is not a regulatory SCR.

The amounts are in millions of euros and are for the financial sample taken as a whole (21.6 incidents a year in the loss database), not for one insurer. The order of magnitude for an entity with 20 000 M$ of assets is given with the results. The level changes by a factor of 22 with the severity source alone. Under the additive construction and the sensitivities examined, we interpret the gap between states and the ordering of pillars; the level remains illustrative.

Approach

SAS OpRisk Global provides 570 IT losses at financial institutions from 2000 to 2026. A generalised Pareto distribution, fitted above 20.03 M€ on 86 exceedances, describes the high losses (tail index 0.5954). The annual incident count is negative binomial. An incident starts in one pillar, then spreads to the others through a directed influence matrix, posited by expert judgement and then bounded. Capital is the 99.5 % quantile of the annual loss, computed in each state.

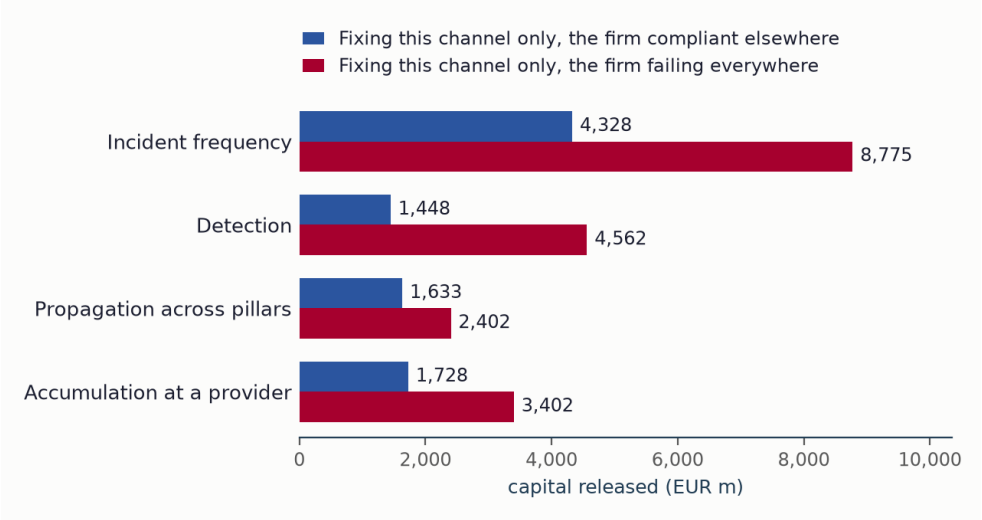
Compliance changes the calculation parameters. Hackmageddon attack-vector shares weight the frequency multiplier. Detection sets the probability that an elementary loss exceeds the threshold, applied to each affected pillar. Propagation sets the probability of continuing the walk between pillars. Finally, an incident starting at provider pillar P4 can affect several other pillars through a common shock. The table gives the values used.

These differences between states are scenario assumptions. The sensitivity tests in Chapter 6 examine their effects; detection multipliers are not swept. The calculation distinguishes a standalone channel effect from the effect of correcting that channel while the others remain degraded.

Channel	Parameter	Compliant	Non-compliant	Standalone	Closure
Frequency	incidents per year	21.6	53.6	4 328	8 775
Detection	exceedance share	0.128	0.181	1 448	4 562
Propagation	cascade gain	0.45	0.90	1 633	2 402
Accumulation	shared provider	0	0.68	1 728	3 402
Capital need (M€)		6 049	20 188		

Results

At the scale of the financial sample, capital need is multiplied by 3.34 between the compliant entity and the entity that is non-compliant on all four channels, a gap of 14 139 M€. The channels taken one by one explain 9 138 M€, and their interactions 5 001 M€, or 35 %. The standalone effect is the capital added by one channel alone, from the compliant state. The closure effect is the capital removed by fixing that channel alone, from the state that is non-compliant on the other three: a remediation plan should quote the second.



Capital released by fixing a single channel (M€, financial sample): in blue from an entity compliant elsewhere (standalone effect), in red from an entity failing everywhere (closure effect). Closure effects do not add up.

The figure shows the ranking of channels. Frequency dominates under both readings. Fixing a channel always releases more capital for an entity failing everywhere, because the channel also closes the interactions it shared with the others. For an entity, the remediation priority therefore depends on its starting state, not only on the standalone effect of each channel.

The gap depends on incident cost. At fixed calibration, Fourier computation gives 13 946 M€ under the additive rule, within one standard error (367 M€) of the Monte Carlo estimate, against 5 946 with a single incident loss. Under the additive rule, the joint bootstrap of severity gives a nominal 95 % band of $[4\,872; 90\,361]$ M€ for the gap, but of $[3.04; 5.22]$ for the factor between states (Chapter 10). The tail makes the level highly uncertain and the factor much less so; both bands remain conditional on frequency and on the other posited parameters.

Public data do not say which pillar drives the other: we compute capital at the 1 024 vertices of the set of admissible influence matrices, the symmetric structure being set by expert judgement. In the reference calibration (compliant-state frequency, gain 0.90), the vertex values range from

6 858 to 8 697 M€; recomputed over four seeds, the width of this range has a standard deviation of 189 M€.

The matrix splits into a symmetric part, the common strength of the links, posited here, and an antisymmetric part, their direction, which none of the sources examined pins down. This range is neither a confidence interval nor a proven bound: it measures the cost of not knowing the direction, at posited strength. For a notional entity with 20 000 M$ of assets, sector capital is scaled down to its size: the need is about 169 M€ (131.5 to 183.3 M€ at the admissible vertices), an extrapolated order of magnitude that depends on the expert-set structure and on the calibration.

Limitations and recommendations

Reference frequency includes twelve losses from before 2000, 2.1 % more than the calibration sample; Chapter 10 explains this convention. Propagation and accumulation are posited. The tested mappings preserve the sign of the gap under the additive rule; pillar-level loss remains unobserved. Calibration bands hold frequency, multipliers and the expert-set cascade fixed.

A likelihood ratio test rejects the Poisson distribution (statistic of 130.5) in favour of the negative binomial. A backtest over 2004–2025 then places 11 years out of 12 inside the 90 % interval of the negative binomial, against 9 out of 12 for the Poisson. This supports the choice without proving it over twelve years. The backtest rejects the annual aggregate level; a drift in tail scale is explored without statistical confirmation. Detecting a doubling of the exceedance rate with 80 % power would require 1 811 years at 99.5 %.

The model primarily supports comparisons of scenarios and closure effects. Setting an actual capital amount or investment requires measuring the entity's states, costs and exposure. A dated register, classified by control domain and recording every pillar hit, would inform direction. VERIS provides these fields; they are filled in together in only one incident out of 10 591.